

PROJECT REPORT

Vulnerability Assessment and Penetration Testing (VAPT) on a Web Application

Internship Project Report

Project Domain: Cybersecurity

Testing Environment: Kali Linux

Summer Internship: 2026

Submitted By

Name: Simranjot Kaur

Roll Number: 72410501

Course: Bachelor of Computer Applications (Cybersecurity & Forensics)

Department: Department of Computer Applications

Institution: CT University, Ludhiana, Punjab

Internship Organization: Allsoft solutions (IBM)

Internship Mentor: Mr. Nikhil Panday

Date of Submission: 17/07/2026

ACKNOWLEDGEMENT

I would like to express my sincere gratitude to my internship mentor for providing me with the opportunity to work on the project "Vulnerability Assessment and Penetration Testing (VAPT) on a Web Application." Their valuable guidance, continuous support, and constructive feedback helped me successfully complete this project and enhance my practical knowledge in the field of cybersecurity.

I am also thankful to the faculty members of the Department of Computer Applications, CT University, for their encouragement and academic support throughout my internship.

I extend my heartfelt thanks to the Allsoft solutions for providing me with an excellent learning environment and the opportunity to gain practical exposure to web application security testing using industry-standard tools and methodologies.

Finally, I would like to express my deepest gratitude to my parents, family, and friends for their constant encouragement, motivation, and support throughout the completion of this internship project.

Submitted By

Simranjot Kaur

BCA (Cybersecurity & Forensics)

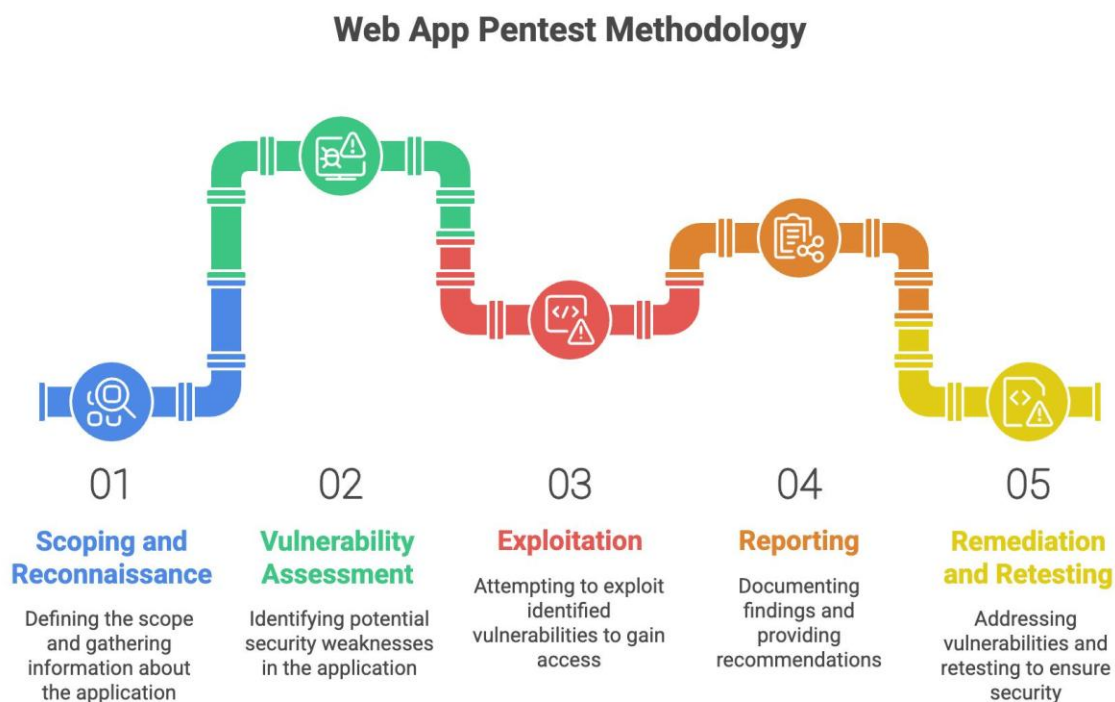
CT University

VULNERABILITY ASSESSMENT AND PENETRATION TESTING (VAPT) ON A WEB APPLICATION

1. Introduction

Web applications have become an essential part of modern organizations for providing online services such as e-commerce, banking, education, healthcare, and social networking. Since these applications store sensitive user information, they are common targets for cyberattacks. Vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), Broken Authentication, and Insecure Direct Object References (IDOR) can allow attackers to steal data, modify application functionality, or gain unauthorized access.

Vulnerability Assessment and Penetration Testing (VAPT) is a comprehensive security assessment methodology used to identify, verify, and exploit security weaknesses in a web application under authorized conditions. Vulnerability Assessment identifies potential security flaws, while Penetration Testing validates whether those vulnerabilities can be successfully exploited by an attacker.



2. Objectives

The objectives of this project are:

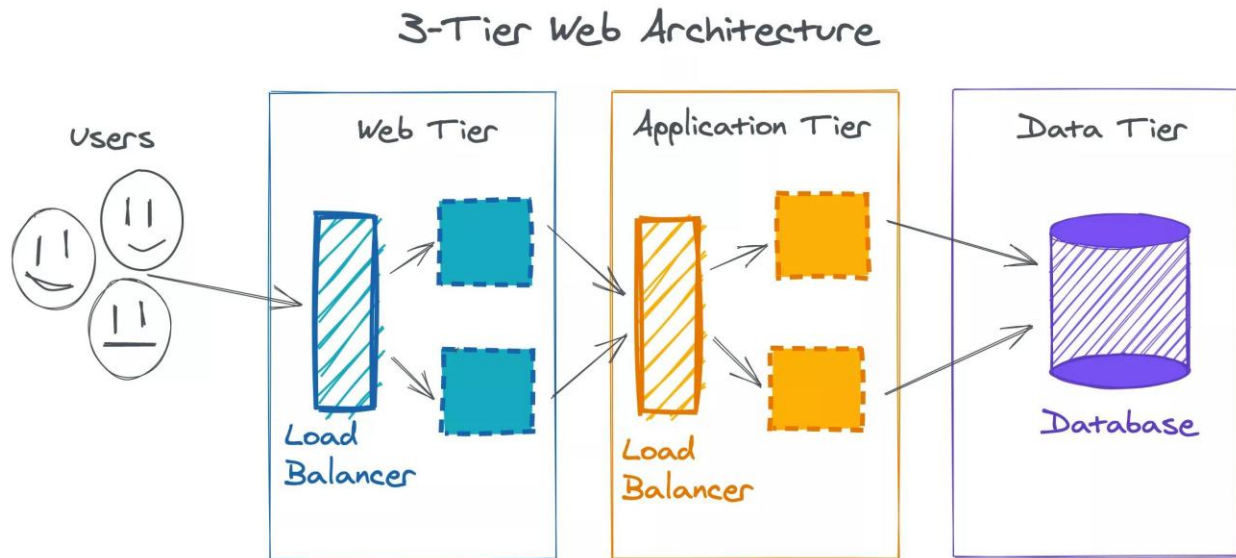
- Identify security vulnerabilities in the web application.
 - Analyze the impact of discovered vulnerabilities.
 - Demonstrate the exploitation of vulnerabilities in a controlled environment.
 - Provide recommendations to mitigate identified security risks.
 - Improve the overall security of the application.
-

3. Scope

The assessment includes the following components:

- Login and Authentication System
- User Registration
- User Dashboard
- Search Functionality
- File Upload Module
- Contact Form
- Session Management
- Database Interaction
- HTTP Headers
- Server Configuration

The assessment excludes denial-of-service attacks and testing of third-party services not owned by the organization.



4. Methodology

The VAPT process follows the following phases:

1. Planning and Authorization
2. Information Gathering
3. Reconnaissance
4. Vulnerability Scanning
5. Manual Testing
6. Exploitation
7. Risk Analysis
8. Reporting
9. Remediation

Phase 1: Planning and Authorization

Before starting the assessment, proper authorization must be obtained from the application owner. Testing without permission is illegal and unethical.

Activities Performed

- Define testing scope.
- Identify target URL/IP.
- Prepare testing environment.
- Install required tools.
- Obtain written permission.

Deliverables

- Scope Document
 - Authorization Letter
 - Testing Plan
-

Phase 2: Information Gathering (Reconnaissance)

Information gathering is the first technical phase of VAPT. The purpose is to collect as much information as possible about the target application.

Information Collected

- Target IP Address
- Domain Name
- DNS Records
- Server Technology
- Programming Language
- Framework
- Database
- Open Ports
- Running Services

Tools Used

- Nmap
- Whois
- nslookup
- WhatWeb
- Wappalyzer

Commands

nmap -A target-ip

Aim: An aggressive scan (-A) collects detailed information by enabling OS detection, service/version detection, scripts, and traceroute in a single command.

```
(kali@kali)-[~]
$ nmap -A 104.21.77.200
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-14 01:01 EST
Nmap scan report for 104.21.77.200
Host is up (0.0048s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http            Cloudflare http proxy
|_http-title: Site doesn't have a title (text/plain; charset=UTF-8).
|_http-server-header: cloudflare
443/tcp   open  ssl/https       cloudflare
|_http-title: 400 The plain HTTP request was sent to HTTPS port
|_http-server-header: cloudflare
8080/tcp   open  http            Cloudflare http proxy
|_http-title: Site doesn't have a title (text/plain; charset=UTF-8).
|_http-server-header: cloudflare
8443/tcp   open  ssl/https-alt?
|_http-title: 400 The plain HTTP request was sent to HTTPS port
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (92%), Slirp (92%), QEMU (88%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (93%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user mode network gateway (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.70 ms  104.21.77.200

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.70 seconds
```

whatweb <http://target-url>

```
(kali@kali)~$ whatweb uptoskills.com
http://uptoskills.com [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[cloudflare], IP[104.21.77.200], RedirectLocation[https://uptoskills.com/UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc]
https://uptoskills.com [200 OK] Country[UNITED STATES][US], Email[info@uptoskills.com], HTML5, HTTPServer[cloudflare], IP[104.21.77.200], Meta-Author[Uptoski 2090,IN,India,New Delhi], Open-Graph-Protocol[website], Script[application/ld+json,module], Strict-Transport-Security[max-age=31536000; includeSubDomains; pr s AI-Powered Hiring & Career Ecosystem], UncommonHeaders[report-to,nel,cf-cache-status,access-control-allow-origin,x-permitted-cross-domain-policies,link,content-n-opener-policy,cross-origin-resource-policy,permissions-policy,referrer-policy,x-content-type-options,x-download-options,speculation-rules,cf-ray,alt-svc], taction[1; mode=block]
https://uptoskills.com/ [200 OK] Country[RESERVED][ZZ], Email[info@uptoskills.com], HTML5, HTTPServer[cloudflare], IP[172.67.211.113], Meta-Author[Uptoskills 0,IN,India,New Delhi], Open-Graph-Protocol[website], Script[application/ld+json,module], Strict-Transport-Security[max-age=31536000; includeSubDomains; prelo I-Powered Hiring & Career Ecosystem], UncommonHeaders[report-to,nel,cf-cache-status,access-control-allow-origin,x-permitted-cross-domain-policies,link,content-n-opener-policy,cross-origin-resource-policy,permissions-policy,referrer-policy,x-content-type-options,x-download-options,speculation-rules,cf-ray,alt-svc], X-F tion[1; mode=block]
```

whois target-domain

```
(kali@kali)~$ whois uptoskills.com
Domain Name: UPTOSKILLS.COM
Registry Domain ID: 2549370386_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.godaddy.com
Registrar URL: http://www.godaddy.com
Updated Date: 2026-07-09T11:31:50Z
Creation Date: 2020-07-29T06:26:04Z
Registry Expiry Date: 2027-07-29T06:26:04Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: 480-624-2505
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientRenewProhibited https://icann.org/epp#clientRenewProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: LENNON.NS.CLOUDFLARE.COM
Name Server: REZA.NS.CLOUDFLARE.COM
DNSSEC: signedDelegation
DNSSEC DS Data: 2371 13 2 E4E18722E69FF26E33CEB5E4F601A9F5DA1F10A814C029081297470FCD5BE7D6
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-07-17T10:46:17Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
```

Expected Output

- Apache Server
- PHP 8.x
- MySQL Database
- Port 80 Open
- Port 443 Open

Phase 3: Website Enumeration

Enumeration identifies hidden resources inside the application.

Objectives

- Discover hidden directories.
- Find backup files.
- Identify admin panels.
- Detect exposed configuration files.

Tools

- Gobuster
- Dirsearch
- ffuf

Example Command

```
gobuster dir -u http://target.com -w  
/usr/share/wordlists/dirb/common.txt
```

Aim: Find hidden directories and files on a website.

```
(kali@kali)-[~]  
$ gobuster dir -u http://uptoskills.com -w /usr/share/wordlists/dirb/common.txt  
=====
```

Gobuster v3.8.2	
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)	

```
=====
```

[+] Url:	http://uptoskills.com
[+] Method:	GET
[+] Threads:	10
[+] Wordlist:	/usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:	404
[+] User Agent:	gobuster/3.8.2
[+] Timeout:	10s

```
=====
```

Starting gobuster in directory enumeration mode

```
=====
```

Progress: 0 / 1 (0.00%)
2026/03/06 04:07:54 the server returns a status code that matches the provided options for non existing urls. http://uptoskills.com/23584606-75d7-48e6-b6f4-341af988201a ⇒ 301 (redirect to https://uptoskills.com/23584606-75d7-48e6-b6f4-341af988201a) (Length: 0). Please exclude the response length or the status code or set the wildcard option.. To continue please exclude the status code or the length

Findings

The scan may reveal:

- /admin
 - /login
 - /uploads
 - /backup
 - /config
-

Phase 4: Fingerprinting

Fingerprinting identifies technologies used to build the application.

Information Identified

- Web Server
- Programming Language
- CMS
- Framework
- Database
- Operating System

Tools

• WhatWeb

```
(kali@kali)~$ whatweb uptoskills.com
http://uptoskills.com [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[cloudflare], IP[104.21.77.200], RedirectLocation[https://uptoskills.com/], UncommonHeaders[speculation-rules,report-to,nel,cf-ray,alt-svc]
https://uptoskills.com [200 OK] Country[UNITED STATES][US], Email[info@uptoskills.com], HTML5, HTTPServer[cloudflare], IP[104.21.77.200], Meta-Author[Uptoski 2090,IN,India,New Delhi], Open-Graph-Protocol[website], Script[application/ld+json,module], Strict-Transport-Security[max-age=31536000; includeSubDomains; preload], UncommonHeaders[report-to,nel,cf-cache-status,access-control-allow-origin,x-permitted-cross-domain-policies,link,content-type-options,x-download-options,speculation-rules,cf-ray,alt-svc], X-Frame-Options[1; mode=block]
https://uptoskills.com/ [200 OK] Country[RESERVED][ZZ], Email[info@uptoskills.com], HTML5, HTTPServer[cloudflare], IP[172.67.211.113], Meta-Author[Uptoski 0,IN,India,New Delhi], Open-Graph-Protocol[website], Script[application/ld+json,module], Strict-Transport-Security[max-age=31536000; includeSubDomains; preload], UncommonHeaders[report-to,nel,cf-cache-status,access-control-allow-origin,x-permitted-cross-domain-policies,link,content-type-options,x-download-options,speculation-rules,cf-ray,alt-svc], X-Frame-Options[1; mode=block]
```

• Wappalyzer

Project: VAPT on a Web Application

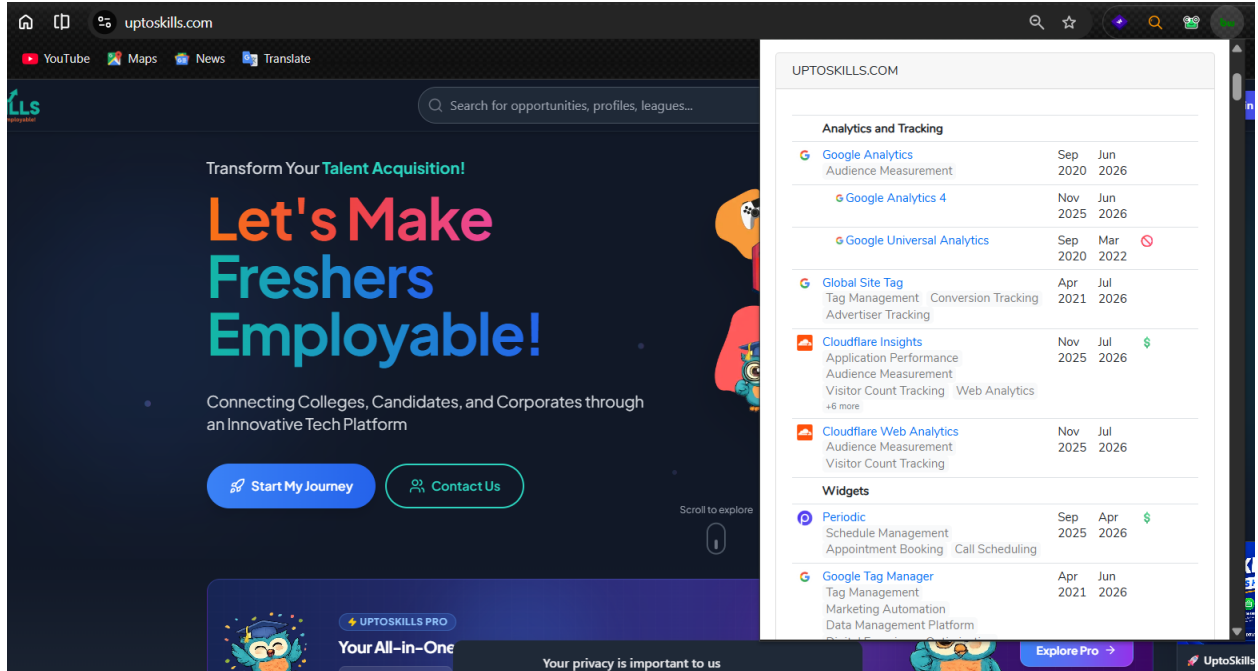
The screenshot shows a web browser with a search result for 'uptoskills.com'. The search results include a link to 'State Approved Course Online - 100% Online - Only \$8-\$10' and a 'Contact Us Today' button. A Wappalyzer overlay is visible on the right side of the browser, displaying a list of technologies detected on the website. The technologies are categorized into Analytics, Security, Web servers, Tag managers, and Reverse proxies. The Wappalyzer overlay also includes a search bar and a list of technologies with their respective icons and names.

Category	Technology
Analytics	Google Analytics GA4
Tag managers	Google Tag Manager
Security	HSTS
Web servers	Apache Traffic Server
Reverse proxies	Envoy

The screenshot shows the Wappalyzer interface with a list of detected technologies. The technologies are categorized into Analytics, Security, Web servers, Tag managers, and Reverse proxies. The Wappalyzer interface also includes a search bar and a list of technologies with their respective icons and names.

Category	Technology
Analytics	Google Analytics GA4
Tag managers	Google Tag Manager
Security	HSTS
Web servers	Apache Traffic Server
Reverse proxies	Envoy

• BuiltWith



[Login](#) [Signup for Free](#) [uptoskills.com](#)

[Tech](#) [Detailed](#) [Meta](#) [Relationship](#) [Redirect](#)

[Recommendations](#) [AI](#)

AI Index

13/100 Limited

AI Index is based on detected AI readiness, openness, maturity and visibility signals.

AI Maturity

0

AI Openness

0

Not an AI Friendly Site

Agent Readiness

0

AI Visibility

50

AI Index Metrics

Metric	Meaning
AI Maturity	Technical ability to implement AI
AI Openness	Willingness to participate in AI ecosystems
Agent Readiness	APIs + structured interfaces

Example Output

- Apache 2.4
 - PHP
 - Bootstrap
 - MySQL
 - Linux Ubuntu
-

Phase 5: Vulnerability Assessment

Automated scanners identify known vulnerabilities.

Tools Used

- OWASP ZAP
- Burp Suite
- Nikto
- Nuclei

Nikto Scan

- **nikto -h <http://target.com>**

```
(kali@kali)-[~]
$ nikto -h https://uptoskills.com
- Nikto v2.5.0

+ Multiple IPs found: 104.21.77.200, 172.67.211.113, 2606:4700:3033::6815:4dc8, 2606:4700:3035::ac43:d371
+ Target IP: 104.21.77.200
+ Target Hostname: uptoskills.com
+ Target Port: 443

+ SSL Info: Subject: /CN=uptoskills.com
           Ciphers: TLS_AES_256_GCM_SHA384
           Issuer: /C=US/O=Google Trust Services/CN=WE1
+ Start Time: 2026-02-28 06:15:43 (GMT-5)

+ Server: cloudflare
+ /: Retrieved access-control-allow-origin header: *.
+ /: Uncommon header 'server-timing' found, with multiple values: (cfCacheStatus;desc="DYNAMIC",cfEdge;dur=6,cfOrigin;du
+ /: Uncommon header 'speculation-rules' found, with contents: "/cdn-cgi/speculation".
+ /: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUI
lla.org/en-US/docs/Web/HTTP/Headers/alt-svc
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of th
to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /robots.txt: contains 23 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossa
+ /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack.
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't connect: SSL negotiation failed
:ssl/tls alert handshake failure at /var/lib/nikto/plugins/LW2.pm line 5254.
at /var/lib/nikto/plugins/LW2.pm line 5254.
; at /var/lib/nikto/plugins/LW2.pm line 5254.
+ Scan terminated: 20 error(s) and 7 item(s) reported on remote host
+ End Time: 2026-02-28 06:17:28 (GMT-5) (105 seconds)

+ 1 host(s) tested
```

Vulnerabilities Detected

- Missing Security Headers
- Server Version Disclosure
- Directory Listing Enabled
- Outdated Software
- Weak SSL Configuration

Phase 6: Manual Penetration Testing

Automated scanners cannot identify every vulnerability. Therefore, manual testing is performed.

6.1 Authentication Testing

Objective

Evaluate authentication mechanisms.

Tests Performed

- Weak Password Testing
- Default Credentials
- Password Complexity
- Password Reset
- Account Lockout
- Multi-factor Authentication

Expected Result

Only authorized users should successfully log in.

6.2 SQL Injection Testing

Objective

Determine whether user inputs interact securely with the database.

Tools

- SQLMap
- Burp Suite

Example SQL Injection Payload

' OR '1'='1

SQLMap Command

```
• sqlmap -u "http://target.com/product.php?id=1" -dbs
```

Project: VAPT on a Web Application

```
(kali@kali)~$  
$ sqlmap -u "http://uptoskills.com/page?id=1" --dbs  
 {1.10.2#stable}  
https://sqlmap.org  
  
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume n  
esponsible for any misuse or damage caused by this program  
  
[*] starting @ 10:31:40 /2026-03-13/  
  
[10:31:40] [INFO] testing connection to the target URL  
[10:31:40] [WARNING] potential permission problems detected ('Access denied')  
[10:31:40] [WARNING] the web server responded with an HTTP error code (403) which could interfere with the results of the tests  
[10:31:40] [INFO] testing if the target URL content is stable  
[10:31:41] [WARNING] target URL content is not stable (i.e. content differs). sqlmap will base the page comparison on a sequence matcher. If no dynamic nor injectable parameters are detected, or in case of junk  
manual paragraph 'Page comparison'  
how do you want to proceed? [(C)ontinue/(s)tring/(r)egex/(q)uit] c  
[10:31:45] [INFO] testing if GET parameter 'id' is dynamic  
[10:31:45] [WARNING] GET parameter 'id' does not appear to be dynamic  
[10:31:45] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable  
[10:31:45] [INFO] testing for SQL injection on GET parameter 'id'  
[10:31:45] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'  
[10:31:46] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'  
[10:31:46] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'  
[10:31:46] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'  
[10:31:46] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'  
[10:31:46] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'  
[10:31:47] [INFO] testing 'Generic inline queries'  
[10:31:47] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'  
[10:31:47] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'  
[10:31:48] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'  
[10:31:48] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'  
[10:31:48] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'  
[10:31:48] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'  
[10:31:49] [INFO] testing 'Oracle AND time-based blind'  
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] y  
[10:31:58] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'  
[10:31:59] [WARNING] GET parameter 'id' does not seem to be injectable
```

Risk

Critical

Impact

- Database Dump
- Credential Theft
- Data Manipulation
- Complete Database Access

Recommendation

- Use Prepared Statements
- Parameterized Queries
- Input Validation

6.3 SSL/TLS Testing

Tools

- SSL Labs

- testssl.sh

Tests

- HTTPS Enabled
- TLS Version
- Weak Cipher Suites
- Certificate Validity

Phase 7: Exploitation

After identifying vulnerabilities, controlled exploitation is performed to verify their existence.

Examples

- Successfully retrieve database names using SQL Injection.
- Execute JavaScript alert using XSS.
- Access another user's profile through IDOR.
- Upload a test file to demonstrate insecure file upload.

Evidence such as screenshots and HTTP requests/responses should be collected during this phase.

Phase 8: Risk Assessment

Each vulnerability is assigned a severity based on the Common Vulnerability Scoring System (CVSS).

Vulnerability	Severity (CVSS Score)	Risk Level
 SQL Injection	9.8	Critical
 Stored XSS	8.8	High
 Broken Authentication	8.1	High
 IDOR	7.5	High
 File Upload	8.6	High
 Missing Security Headers	4.3	Medium
 Directory Listing	3.7	Low

Phase 9: Remediation

SQL Injection

- Use Prepared Statements.
- Implement Parameterized Queries.
- Validate all user inputs.

Cross-Site Scripting

- Encode all output.
- Sanitize user input.
- Deploy a Content Security Policy.

Broken Authentication

- Enforce strong passwords.
- Enable Multi-Factor Authentication.
- Secure session management.

File Upload

- Restrict allowed file types.
- Verify MIME types.
- Scan uploaded files with antivirus.
- Store uploads outside the web root.

Security Headers

Configure the following headers:

- Content-Security-Policy
- Strict-Transport-Security
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy

Tools Used

Tool	Purpose
 Nmap	Network Scanning
 WhatWeb	Technology Detection
 Gobuster	Directory Enumeration
 Burp Suite	Intercepting and Manual Testing
 OWASP ZAP	Automated Web Vulnerability Scanning
 Nikto	Web Server Vulnerability Scanning
 SQLMap	SQL Injection Testing
 Nuclei	Template-Based Vulnerability Scanning
 Wireshark	Network Packet Analysis
 Firefox + FoxyProxy	Proxy Configuration

Conclusion:

The VAPT assessment successfully identified multiple security vulnerabilities affecting the confidentiality, integrity, and availability of the web application. Automated scanning combined with manual penetration testing provided a comprehensive evaluation of the application's security posture. Critical issues such as SQL Injection, Cross-Site Scripting (XSS), Broken Authentication, and Insecure Direct Object References (IDOR) demonstrated the importance of secure coding practices, proper input validation, robust authentication mechanisms, and secure server configuration.